

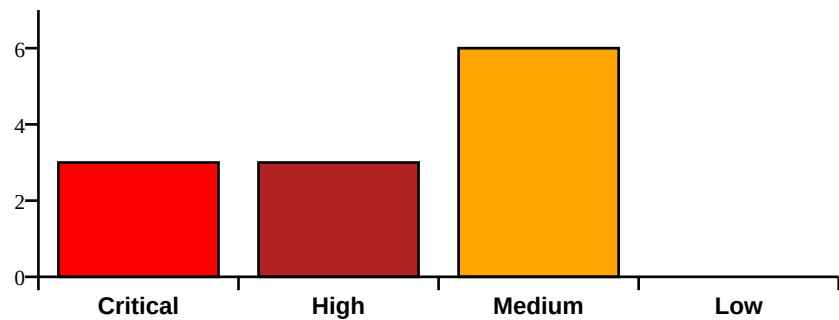
Vulnerability Scan Report

Target URL: http://localhost:3000
Generated (UTC): 2026-04-26 08:15:04Z

Summary

Metric	Count
Total Vulnerabilities	12
Critical Severity	3
High Severity	3
Medium Severity	6
Low Severity	0

Severity Distribution



Detailed Findings

- 1. Cryptographic Failure (High)**
Location: http://localhost:3000
Evidence:
Application does not enforce HTTPS.
- 2. Cryptographic Failure (Medium)**
Location: http://localhost:3000
Evidence:
Strict-Transport-Security header not set.
- 3. Cryptographic Failure (Medium)**
Location: http://localhost:3000/rest/admin/application-configuration
Evidence:
Possible SHA1 hash found in response from http://localhost:3000/rest/admin/application-configuration.
- 4. Cryptographic Failure (Medium)**
Location: http://localhost:3000/rest/memories/
Evidence:
Possible MD5 hash found in response from http://localhost:3000/rest/memories/.

5. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: token → Secure=False

Evidence:

Cookie transmitted without Secure flag.

6. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: token → HttpOnly=False

Evidence:

Cookie accessible via JavaScript (XSS risk).

7. Identification & Authentication Failures (High)

Location: http://localhost:3000/#/login

Payload: exp field missing

Evidence:

JWT does not expire - can be reused indefinitely.

8. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.password = 0192023a7bbd73250516f069df18b500

Evidence:

Sensitive data exposed inside JWT payload.

9. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.deluxeToken =

Evidence:

Sensitive data exposed inside JWT payload.

10. Identification & Authentication Failures (Critical)

Location: http://localhost:3000/#/login

Payload: data.totpSecret =

Evidence:

Sensitive data exposed inside JWT payload.

11. Identification & Authentication Failures (Medium)

Location: http://localhost:3000/#/login

Payload: role = admin

Evidence:

User role exposed in JWT.

12. Identification & Authentication Failures (High)

Location: http://localhost:3000/#/login

Payload: Token stored in browser localStorage

Evidence:

Token accessible via JavaScript (XSS risk).

Activity Log

```
[08:06:09]
=====
[08:06:09] Starting Vulnerability Scan for http://localhost:3000
[08:06:09]
=====
[08:06:09] [*] Starting active crawl (mode=deep, headless=False)...
[08:06:09] [*] _async_crawl started.
[08:06:10] [*] Launching browser...
[08:06:10] [*] Browser launched and page created.
[08:06:10] [*] Navigating to login page...
[08:06:11] [*] Looking for login fields...
[08:06:11] [*] Login fields found – email inputs: 1, password inputs: 1
[08:06:11] [*] Credentials filled, submitting...
[08:06:41] [*] Error during login submission: Locator.click: Timeout 30000ms exceeded.
Call log:
  - waiting for locator('button[type=submit]')
  - locator resolved to <button type=submit color=primary
id="loginButton" aria-label="Login" mat-raised-button=
ng-c4166025290="" mat-ripple-loader-uninitialized="" mat-ripple-loader-class-
name="mat-mdc-button-ripple" class="mdc-button mat-mdc-button-base mdc-button--raised mat-mdc-
raised-button mat-primary"> from <div
class="cdk-overlay-container" subtree intercepts pointer events
  - retrying click action
  - waiting 20ms
  2 x waiting for element to be visible, enabled and stable
  - element is visible, enabled and stable
  - scrolling into view if needed
  - done scrolling
  - <div class="mat-mdc-dialog-surface mdc-dialog__surface" from <div
class="cdk-overlay-container" subtree intercepts pointer events
  - retrying click action
  - waiting 100ms
  25 x waiting for element to be visible, enabled and stable
  - element is visible, enabled and stable
  - scrolling into view if needed
  - done scrolling
  - <div class="mat-mdc-dialog-surface mdc-dialog__surface" from <div
class="cdk-overlay-container" subtree intercepts pointer events
  - retrying click action
  - waiting 500ms

[08:06:41] [*] Visiting (0): http://localhost:3000
[08:06:43] [+] Endpoint discovered: http://localhost:3000/assets/i18n/en.json
[08:06:43] [+] Endpoint discovered: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv44
[08:06:43] [+] Endpoint discovered: http://localhost:3000/rest/admin/application-version
[08:06:43] [+] Endpoint discovered: http://localhost:3000/rest/admin/application-configuration
[08:06:43] [+] Endpoint discovered: http://localhost:3000/api/Challenges/?name=Score%20Board
[08:06:43] [+] Endpoint discovered: http://localhost:3000/rest/languages
[08:06:43] [+] Endpoint discovered: http://localhost:3000/api/Quantities/
[08:06:43] [+] Endpoint discovered: http://localhost:3000/rest/products/search?q=
[08:06:43] [+] Endpoint discovered:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5E&sid=k_GckfkUk0hjdTtEAAAU
[08:06:43] [+] Endpoint discovered:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5E.0&sid=k_GckfkUk0hjdTtEAAAU
[08:06:43] [+] Endpoint discovered:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5j&sid=k_GckfkUk0hjdTtEAAAU
[08:08:52] [*] Visiting (1): http://localhost:3000/#/
[08:08:53] [+] Endpoint discovered: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0yX
[08:08:53] [+] Endpoint discovered:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0z7&sid=zy9DVMUo80hBm4CAAAA4
[08:08:53] [+] Endpoint discovered:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0z9&sid=zy9DVMUo80hBm4CAAAA4
[08:08:53] [+] Endpoint discovered:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0zP&sid=zy9DVMUo80hBm4CAAAA4
[08:12:27] [*] Visiting (2): http://localhost:3000/#/search
[08:14:40] [*] Crawl loop finished. Visited: 3, Clicks: 12
[08:14:40] [*] Browser closed.
[08:14:40] [+] Found page: http://localhost:3000
[08:14:40] [+] Found page: http://localhost:3000/#/
[08:14:40] [+] Found page: http://localhost:3000/#/search
[08:14:40] [+] Found API endpoint: http://localhost:3000/assets/i18n/en.json
[08:14:40] [+] Found API endpoint: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv44
```

```

[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/admin/application-version
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/admin/application-configuration
[08:14:40] [+] Found API endpoint: http://localhost:3000/api/Challenges/?name=Score%20Board
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/languages
[08:14:40] [+] Found API endpoint: http://localhost:3000/api/Quantities/
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/products/search?q=
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5E&sid=k_GckfkUk0hjdTtEAAU
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5E.0&sid=k_GckfkUk0hjdTtEAAU
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5j&sid=k_GckfkUk0hjdTtEAAU
[08:14:40] [+] Found API endpoint: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rM-j
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rM_i&sid=k_rAv881YyNEGpy7AAAw
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rM_l&sid=k_rAv881YyNEGpy7AAAw
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rN09&sid=k_rAv881YyNEGpy7AAAw
[08:14:40] [+] Found API endpoint: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNRI
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNSE&sid=vqHuy9A_dx7vYygRAAAy
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNSG&sid=vqHuy9A_dx7vYygRAAAy
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNSa&sid=vqHuy9A_dx7vYygRAAAy
[08:14:40] [+] Found API endpoint: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNy4
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNyj&sid=K8WjjeK4gW37IZonAAA0
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNyl&sid=K8WjjeK4gW37IZonAAA0
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNz7&sid=K8WjjeK4gW37IZonAAA0
[08:14:40] [+] Found API endpoint: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOTV
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOU7&sid=MI4FKNCVks_Z_CylAAA2
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOU8&sid=MI4FKNCVks_Z_CylAAA2
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOUR&sid=MI4FKNCVks_Z_CylAAA2
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/user/whoami?fields=email
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/products/1/reviews
[08:14:40] [+] Found API endpoint: http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOyX
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOz7&sid=zy9DVMUo80hBm4CAAAA4
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOz9&sid=zy9DVMUo80hBm4CAAAA4
[08:14:40] [+] Found API endpoint:
http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rOzP&sid=zy9DVMUo80hBm4CAAAA4
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/user/whoami?fields=id,email
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/captcha/
[08:14:40] [+] Found API endpoint: http://localhost:3000/api/Feedbacks/
[08:14:40] [+] Found API endpoint: http://localhost:3000/rest/memories/
[08:14:40] [*] Active crawl complete. Links: 3, API endpoints: 37
[08:14:40]
===== SCANNING http://localhost:3000 =====

```

```

[08:14:40] [INFO] Checking scheme → http
[08:14:40] [INFO] Initiating TLS handshake
[08:14:45] [SKIP] TLS check skipped → [WinError 10061] No connection could be made because the target machine
actively refused it
[08:14:45] [INFO] Checking cipher suite
[08:14:49] [SKIP] Cipher check skipped → [WinError 10061] No connection could be made because the target
machine actively refused it
[08:14:49] [INFO] Retrieving TLS certificate
[08:14:53] [SKIP] Certificate check skipped → [WinError 10061] No connection could be made because the target
machine actively refused it
[08:14:53] [HTTP] Checking HSTS header
[08:14:53] [HTTP] Response status → 200
[08:14:53] [HTTP] Response headers → {&#x27;Access-Control-Allow-Origin&#x27;; &#x27;*&#x27;; &#x27;X-Content-
Type-Options&#x27;; &#x27;nosniff&#x27;; &#x27;X-Frame-Options&#x27;; &#x27;SAMEORIGIN&#x27;; &#x27;Feature-
Policy&#x27;; &#x27;payment &#x27;self&#x27;&quot;; &#x27;X-Recruiting&#x27;; &#x27;/#/jobs&#x27;;
&#x27;Accept-Ranges&#x27;; &#x27;bytes&#x27;; &#x27;Cache-Control&#x27;; &#x27;public, max-age=0&#x27;;
&#x27;Last-Modified&#x27;; &#x27;Sun, 26 Apr 2026 05:45:49 GMT&#x27;; &#x27;ETag&#x27;;
&#x27;W/&quot;124fa-19dc8529929&quot;&#x27;; &#x27;Content-Type&#x27;; &#x27;text/html; charset=UTF-8&#x27;;
&#x27;Vary&#x27;; &#x27;Accept-Encoding&#x27;; &#x27;Content-Encoding&#x27;; &#x27;gzip&#x27;;
&#x27;Date&#x27;; &#x27;Sun, 26 Apr 2026 08:14:53 GMT&#x27;; &#x27;Connection&#x27;; &#x27;keep-alive&#x27;;
&#x27;Keep-Alive&#x27;; &#x27;timeout=5&#x27;; &#x27;Transfer-Encoding&#x27;; &#x27;chunked&#x27;}}
[08:14:53] [SCAN] Scanning 38 URL(s) for sensitive data exposure...
[08:14:53] [SCAN] Checking http://localhost:3000 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/assets/i18n/en.json for sensitive data...

```

```

[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv44 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/admin/application-version for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/admin/application-configuration for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/api/Challenges/?name=Score%20Board for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/languages for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/api/Quantities/ for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/products/search?q= for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5E&sid=k_GckfkUk0hjdTtEAAU for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5E.0&sid=k_GckfkUk0hjdTtEAAU for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8qv5j&sid=k_GckfkUk0hjdTtEAAU for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rM-j for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rM_i&sid=k_rAv881YyNEGpy7AAW for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rM_l&sid=k_rAv881YyNEGpy7AAW for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rN09&sid=k_rAv881YyNEGpy7AAW for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNri for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNSE&sid=vqHuy9A_dx7vYygRAAAy for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNSG&sid=vqHuy9A_dx7vYygRAAAy for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNSa&sid=vqHuy9A_dx7vYygRAAAy for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNy4 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNyj&sid=K8WjjeK4gW37IZonAAA0 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNyl&sid=K8WjjeK4gW37IZonAAA0 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8rNz7&sid=K8WjjeK4gW37IZonAAA0 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0TV for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0U7&sid=MI4FKNCVks_Z_CylAAA2 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0U8&sid=MI4FKNCVks_Z_CylAAA2 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0UR&sid=MI4FKNCVks_Z_CylAAA2 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/user/whoami?fields=email for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/products/1/reviews for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0yX for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0z7&sid=zy9DVMUo80hBm4CAAAA4 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0z9&sid=zy9DVMUo80hBm4CAAAA4 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/socket.io/?EIO=4&transport=polling&t=Pt8r0zP&sid=zy9DVMUo80hBm4CAAAA4 for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/user/whoami?fields=id,email for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/captcha/ for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/api/Feedbacks/ for sensitive data...
[08:14:53] [SCAN] Checking http://localhost:3000/rest/memories/ for sensitive data...
[08:14:53]
===== REPORT =====
[08:14:53] - [High] HTTPS not enforced

```

```

[08:14:53] - [Medium] HSTS header missing
[08:14:53] - [Medium] SHA1 hash exposed
[08:14:53] - [Medium] MD5 hash exposed
[08:14:53]
===== SCORE =====
[08:14:53] Crypto Risk Score → 70/100
[08:14:53] Risk Level → HIGH
[08:14:57] [+] Looking for login form...
[08:15:00] [+] Found login form at http://localhost:3000/#/login
[08:15:00] [+] Login form detected dynamically.
[08:15:00] [+] Logging in with provided credentials...
[08:15:02] [+] Analyzing cookies...
[08:15:02] [!] Missing Secure flag on token
[08:15:02] [!] Missing HttpOnly flag on token
[08:15:02] [+] Analyzing JWT token...
[08:15:02] [+] JWT token found.
[08:15:02] [JWT HEADER] {
  "typ";: "JWT";,
  "alg";: "RS256";
}
[08:15:02] [JWT PAYLOAD] {
  "status";: "success";,
  "data";: {
    "id";: 1,
    "username";: "";,
    "email";: "admin@juice-sh.op";,
    "password";: "0192023a7bbd73250516f069df18b500";,
    "role";: "admin";,
    "deluxeToken";: "";,
    "lastLoginIp";: "";,
    "profileImage";: "assets/public/images/uploads/defaultAdmin.png";,
    "totpSecret";: "";,
    "isActive";: true,
    "createdAt";: "2026-04-26 05:45:44.729 +00:00";,
    "updatedAt";: "2026-04-26 05:45:44.729 +00:00";,
    "deletedAt";: null
  },
  "iat";: 1777191301
}
[08:15:04]
[*] Generating PDF report...

```